

NAME: Chougle Talha Zahoor Ahmed

Email id: tchougle60@gmail.com

College Name: Royal College of Arts, Science and Commerce

Task 1: Introduction

Aim

To understand the **scope of post-exploitation** and prepare the target machine for enumeration and attacks.

Steps Performed

- Deployed the Windows Server machine.
- Waited for services (RDP/SSH) to fully initialize.
- Prepared to enumerate the domain after shell access.

Logic

Enterprise servers take time to initialize **Active Directory services**, Kerberos, and domain controllers.

Rushing access before services are ready can lead to **false enumeration results**.

Task 2: Enumeration w/ PowerView

Aim

To enumerate **domain users, groups, and privileges** after gaining administrative access.

Steps Performed

1. Launched PowerShell with execution policy bypass.
2. Loaded the PowerView script.
3. Enumerated:
 - Domain users
 - Administrative groups
4. Continued deeper enumeration using PowerView cheat sheets.

Logic

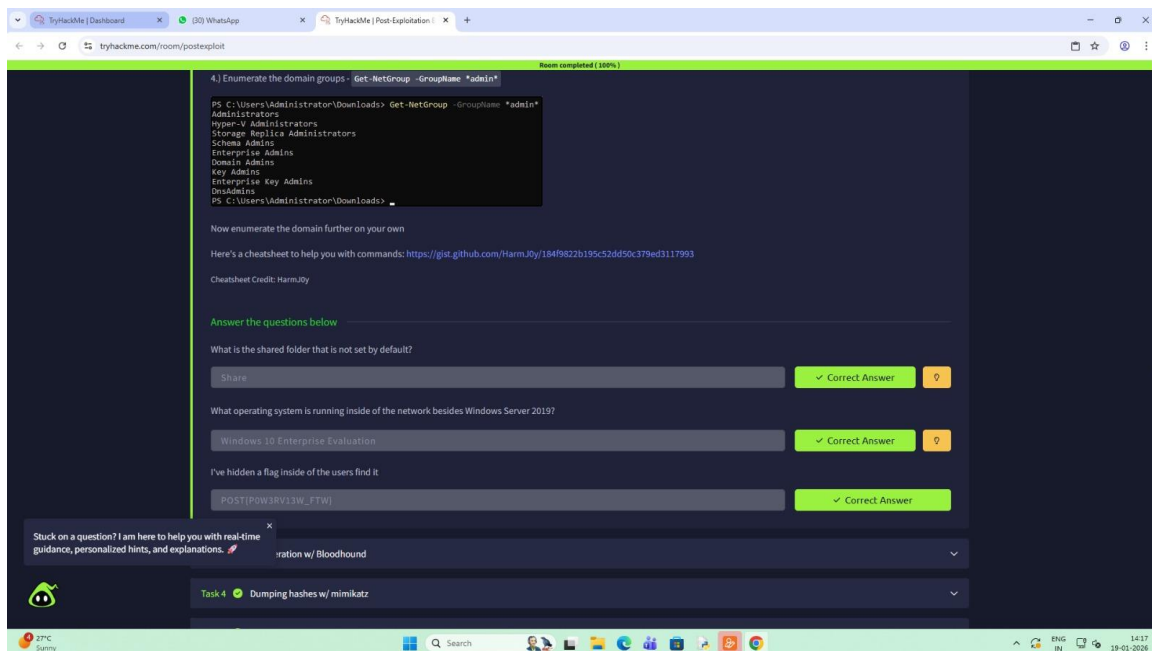
PowerView leverages **native Active Directory APIs**, making it:

- Stealthy
- Reliable
- Highly effective post-compromise

Knowing **users and privileged groups** helps attackers identify:

- High-value accounts
- Privilege escalation paths
- Lateral movement opportunities

Screenshot:



Task 3: Enumeration w/ Bloodhound

Aim

To visually map **Active Directory relationships** and identify attack paths.

Steps Performed

1. Installed BloodHound and Neo4j on the attacker machine.
2. Used SharpHound on the compromised server to collect:

- Users
 - Groups
 - Sessions
 - ACLs
3. Exported data as `.json` files.
 4. Imported the data into BloodHound.
 5. Executed built-in queries.

Logic

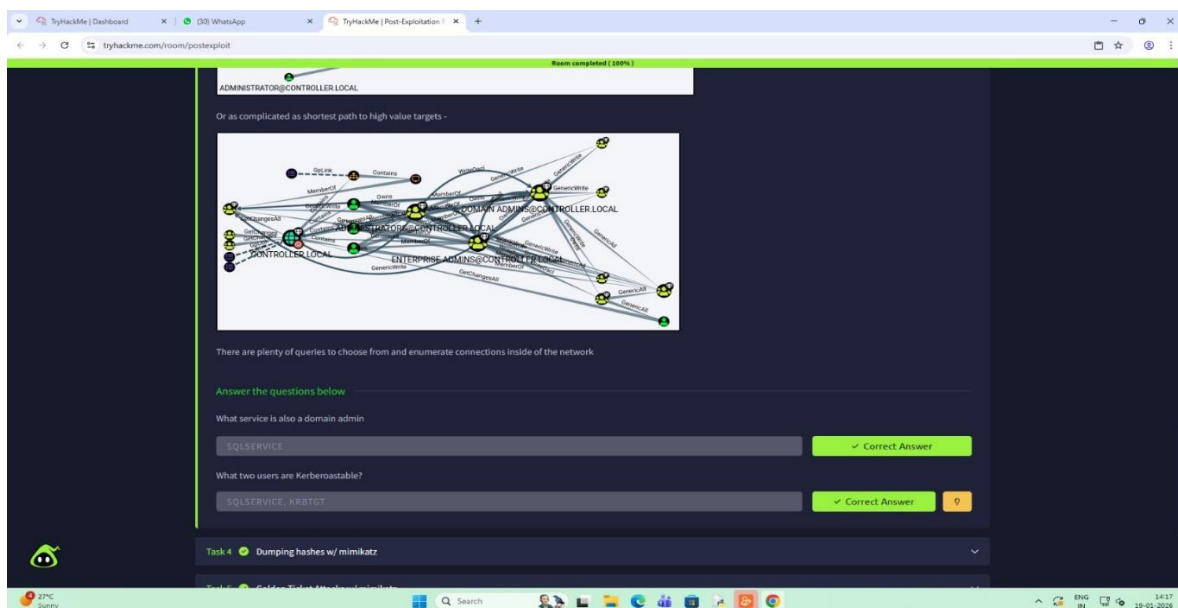
Active Directory attacks are **relationship-based**, not machine-based.

BloodHound reveals:

- Hidden privilege escalation paths
- Misconfigured permissions
- Shortest path to Domain Admin

This replaces **manual guessing** with **graph-based certainty**.

Screenshot:



Task 4: Dumping hashes w/ mimikatz

Aim

To extract **NTLM password hashes** from memory and crack them offline.

Steps Performed

1. Executed Mimikatz with administrative privileges.
2. Enabled debug privileges.
3. Dumped LSA secrets (NTLM hashes).
4. Cracked hashes using Hashcat and a wordlist.

Logic

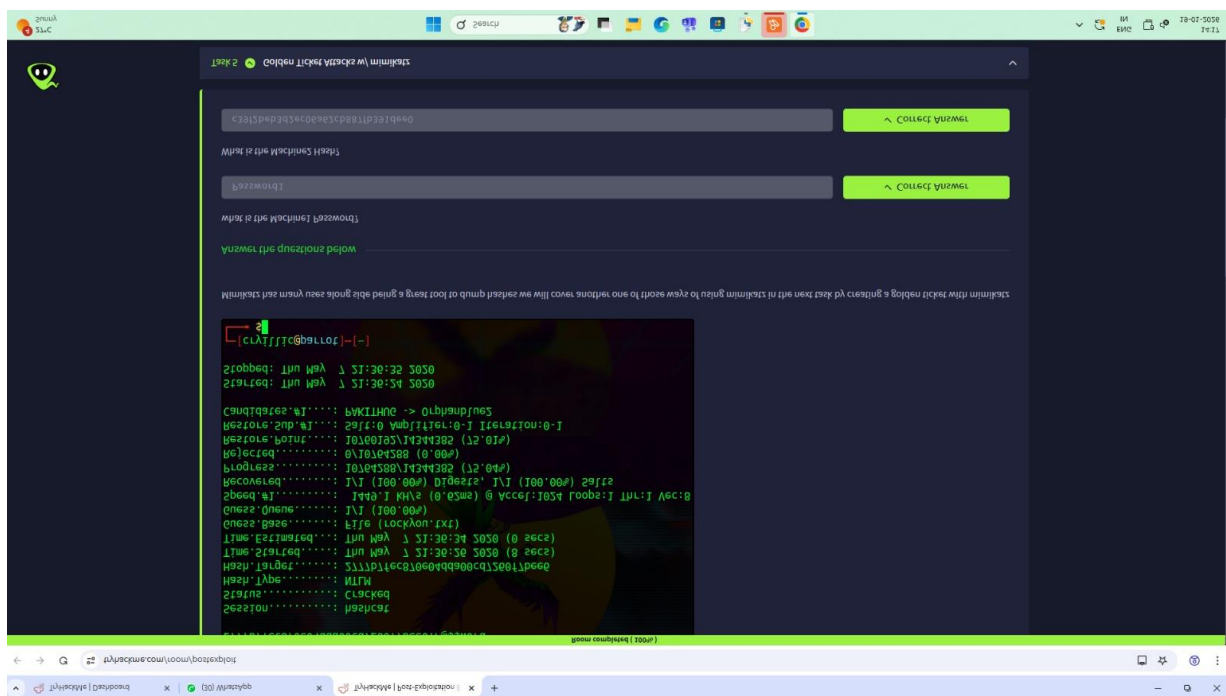
Windows stores credentials in memory for authentication efficiency.

Mimikatz exploits this to retrieve credentials **without touching disk**, making it extremely powerful.

Cracked hashes can be reused for:

- Pass-the-Hash attacks
- Lateral movement
- Privilege escalation

Screenshot:



Task 5: Golden Ticket Attacks w/ mimikatz

Aim

To create a **forged Kerberos Ticket (Golden Ticket)** granting unrestricted domain access.

Steps Performed

1. Extracted:
 - `krbtgt` NTLM hash
 - Domain SID
2. Used Mimikatz to generate a Golden Ticket.
3. Injected the ticket into memory.
4. Spawned a privileged command shell.

Logic

Kerberos trusts the **krbtgt account** to validate tickets.
If compromised, attackers can:

- Forge authentication indefinitely
- Access any system
- Bypass password changes

This is one of the **most severe AD compromises possible**.

Task 6: Enumeration w/ Server Manager

Aim

To enumerate the domain using **legitimate Windows administrative tools**.

Steps Performed

1. Connected via RDP.
2. Opened Server Manager.
3. Explored:
 - Users
 - Groups
 - Trust relationships
4. Inspected user descriptions for stored credentials.

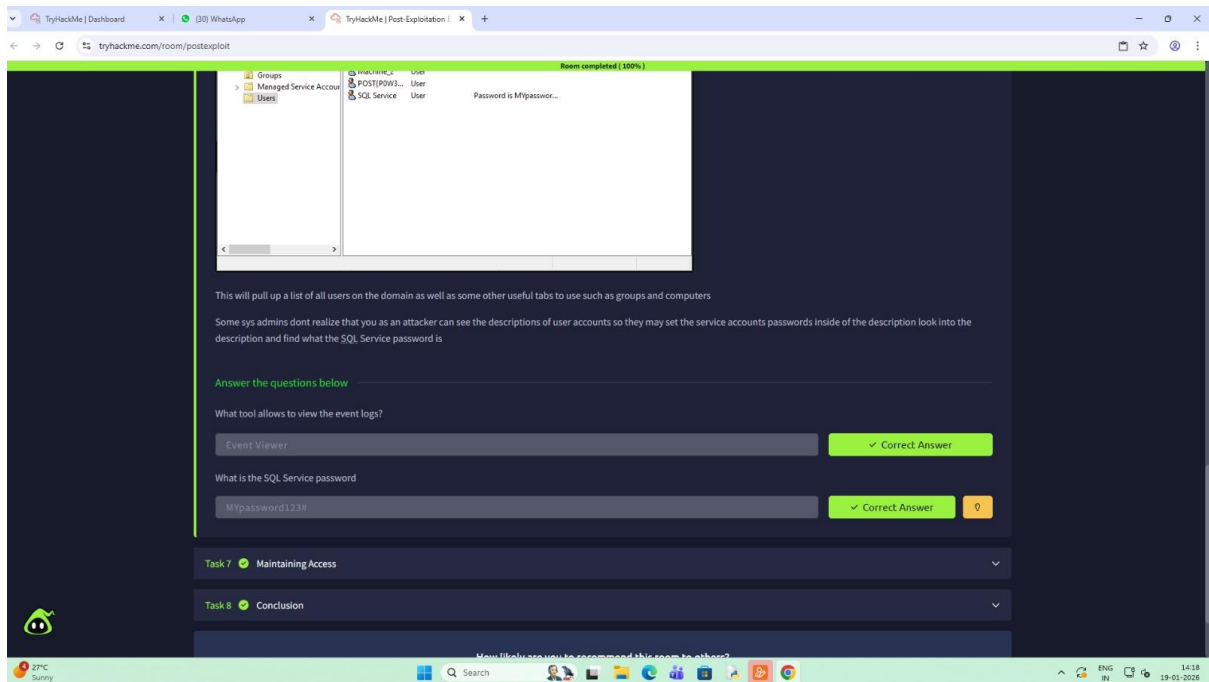
Logic

Many system administrators **store passwords in account descriptions**.
Using native tools:

- Avoids detection
- Blends with normal admin activity
- Requires no malware

This is known as **Living Off the Land (LOLBins)**.

Screenshot:



Task 7: Maintaining Access

Aim

To maintain long-term access even after system reboot.

Steps Performed

1. Generated a Meterpreter payload with msfvenom.
2. Executed the payload to gain a session.
3. Backgrounded the session.
4. Deployed the Metasploit persistence module.
5. Verified reconnection after session loss.

Logic

Attackers assume:

- Reboots will happen
- Sessions will die

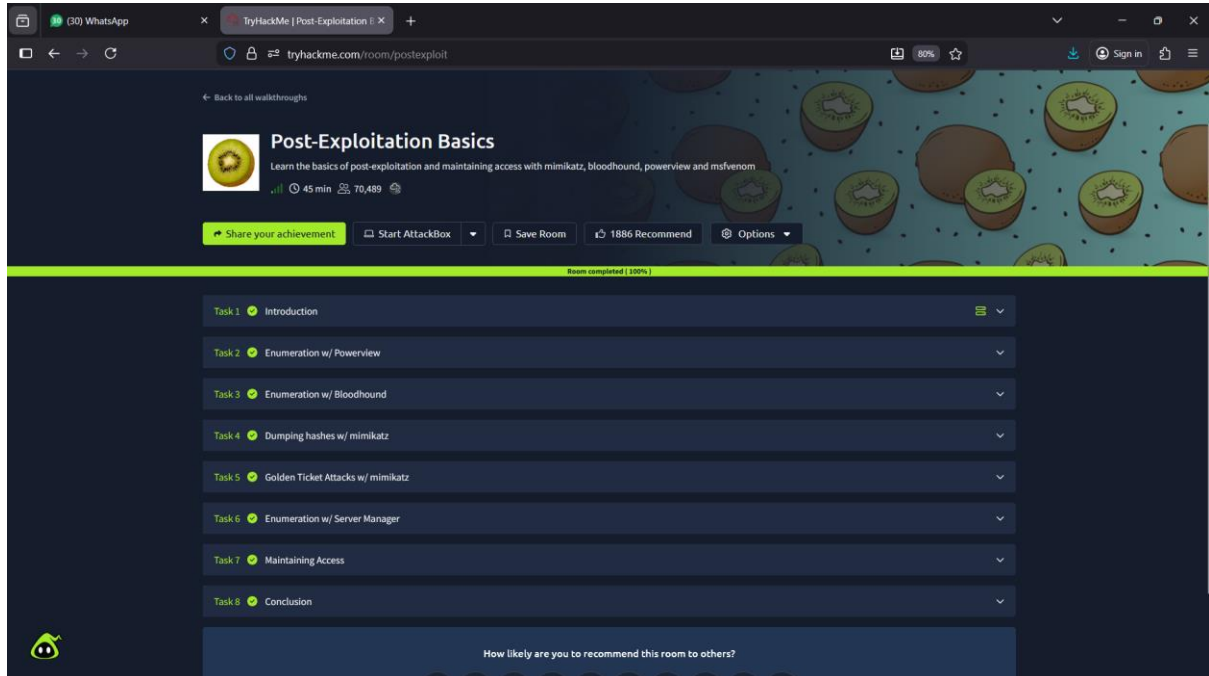
Persistence ensures:

- Automatic callback
- Continued control

- No need for re-exploitation

This simulates real attacker behavior

Screenshot:



Task 8: Conclusion

Overall Aim

To simulate real-world post-exploitation techniques used after domain compromise.

Key Learnings

- Enumeration is more valuable than exploitation
- Active Directory attacks rely on relationships
- Credential access leads to complete domain compromise
- Persistence ensures attacker longevity

Conclusion

This lab demonstrates how one compromised machine can lead to:

- Domain Admin access
- Credential theft
- Full network takeover

Understanding these techniques is critical for:

- Defensive security
- Incident response
- Red team operations